PowerMF

Программное обеспечение для двухфакторной аутентификации

Руководство администратора

Оглавление

Оглавление....1
Краткое описание....2
Работа с Active Directory, подробное описание....5
Использование LDAP over SSL....6
Использование генераторов одноразовых паролей (программных или аппаратных)....6
Настройка параметров....7
Параметры в файле settings.json....7
Блокировка подключения....12
Блокировка аутентификации по IP адресам и странам....12
Блокировка пользователя при попытке подбора одноразового пароля....13
Режим первичной аутентификации....14
Установка....15
Установка из репозитория GitHub....15
Журналирование....16
Отладка....17
Настройка VPN шлюза....18
Настройка шлюза VPN на примере Cisco ASA....18
Настройка Active Directory....19
Настройка Active Directory с помощью Powershell....19
Пример настройки Active Directory через графический интерфейс....21
Тестирование....22
Инструменты тестирования....22
Отказоустойчивость....23
Изменения и дальнейшее развитие....23
Расположение файлов....23
Контакты....24

Краткое описание

Программное обеспечение ***PowerMF*** предназначено для двухфакторной аутентификации пользователей, при подключении к корпоративным сетям посредством виртуальных частных сетей (VPN).

Устанавливается на серверах внутри компании (on premise).

Доступ к сети Internet требуется только для доставки одноразовых паролей посредством сообщений SMS или электронной почты.

ПО ***PowerMF*** выполнено в виде единого исполняемого файла без зависимостей от внешних библиотек.

Архитектурно, ПО ***PowerMF*** состоит из следующих компонентов:

- **RADIUS** сервер, на который приходят запросы от шлюзов VPN
- **LDAP** клиент, выполняющий запросы в службу каталога, для получения атрибутов пользователя и/или его аутентификации, а также блокировки учетной записи
- **SNMP** клиент, выполняющий отправку одноразового пароля по электронной почте
- **HTTPS** клиент, выполняющий работу с API провайдера SMS услуг, а также получения данных о IP адресах из базы данных RIPE
- **SYSLOG** клиент, выполняющий отправку сообщений журнала в SIEM
- Различных очередей и их обработчиков

Управление параметрами пользователя осуществляется полностью в **Active Directory** (или другой службе каталога, поддерживающей протокол LDAP) посредством задания атрибутов и членства в группах, инструментами управления службой каталога.

Настройка ПО ***PowerMF***, выполняется путем редактирования конфигурационных файлов в формате JSON

Процесс работы:

ПО ***PowerMF*** получает запрос на аутентификацию пользователя по протоколу **RADIUS**.

Производится поиск пользователя в службе каталога (**Active Directory**), в случае успеха, проверяется его членство в группе, разрешающей подключение (параметр **otp_group** в секции **ldap_setting** файла **settings.json**) если пользователь является членом этой группы, проверяются атрибуты:

- **mobile** - Мобильный телефон
- **mail** - электронная почта
- **info** - заметки на вкладке телефоны

В поле Заметки можно указать предпочитаемый метод доставки одноразового пароля:

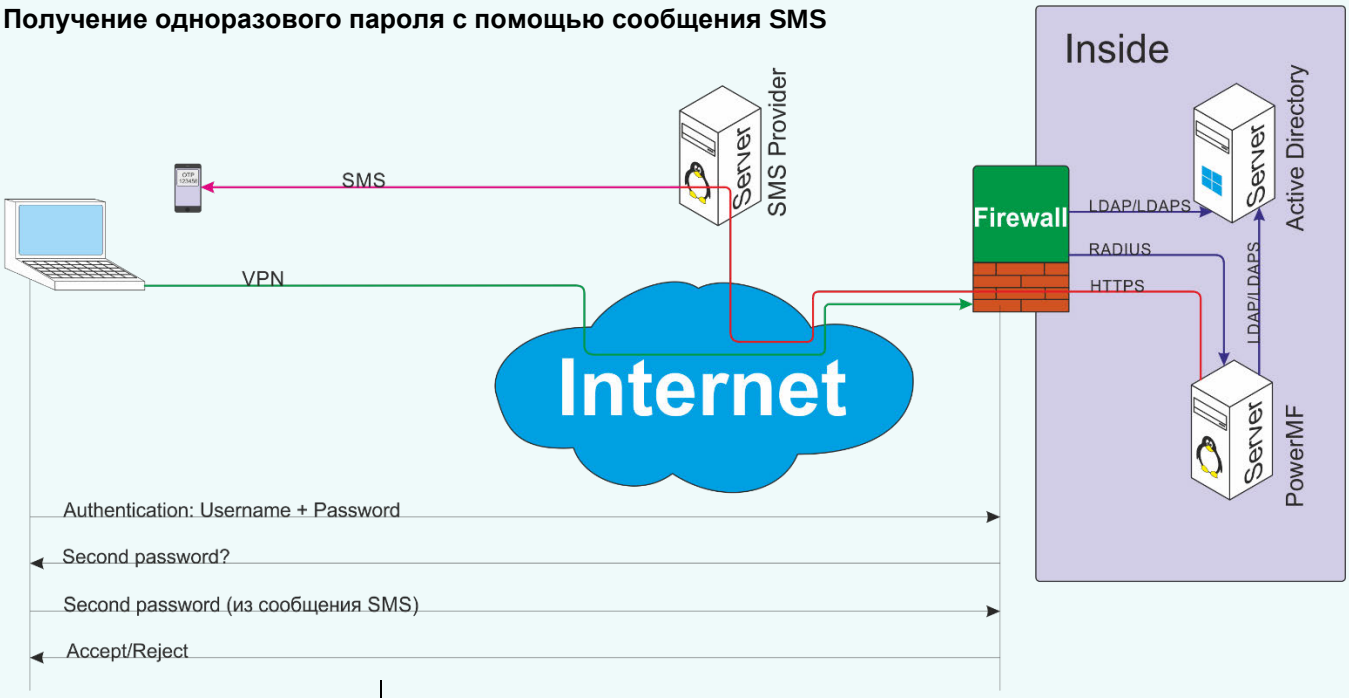
- **otpmail** - для отправки одноразового пароля по электронной почте
- **otpsms** - для отправки одноразового пароля по SMS

если в этом поле уже имеется текст, укажите метод доставки в конце текста, отделив его запятой или пробелом.

Для отправки сообщений SMS требуется промежуточный сервис (мы предоставляем встроенную интеграцию с **СМС Дисконт** и **МТС**)

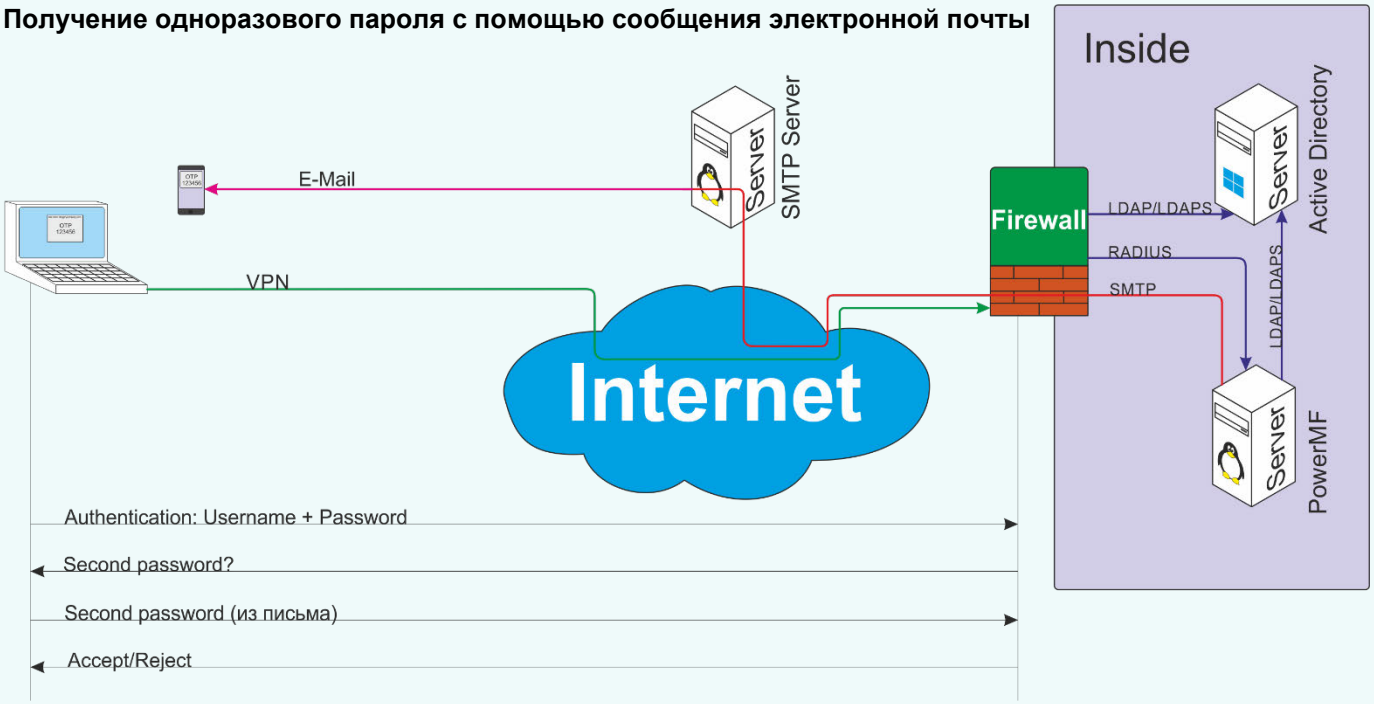
Ниже представленны диаграммы работы ***PowerMF***, при использовании SMS, электронной почты и аппаратного или программного генератора одноразовых паролей (токена):

Получение одноразового пароля с помощью сообщения SMS



Преимущества	Недостатки
Не требуется токен	Для получения сообщения SMS, необходимо наличие сотовой связи
Не требуется передача секретного ключа	Услуги провайдера SMS могу быть достаточно дороги

Получение одноразового пароля с помощью сообщения электронной почты



Преимущества	Недостатки
Не требуется токен	Для получения письма электронной почты, необходим доступ к почтовому ящику до подключения по VPN
Не требуется передача секретного ключа	Учетные данные для доступа к электронной почте, желательно использовать, отличные от первичной аутентификации на VPN шлюзе

Подключение, с использованием генератора одноразового пароля (TOTP)



Преимущества	Недостатки
Не требуется наличие сотовой связи или доступ к почтовому ящику	В случае использования программных токенов или аппаратных программируемых токенов необходимо безопасно передать секретный ключ
Нет необходимости ждать прихода одноразового пароля	
В случае аппаратного токена выше безопасность	

Работа с Active Directory, подробное описание

Все управление пользователями, производится через **Active Directory** (либо средствами администрирования аналогичной службы каталога).

Для того чтобы пользователь мог подключаться по VPN его необходимо сделать членом группы, указанной в конфигурационном файле (параметр **otp_group** в секции **ldap_setting** файла **settings.json**).

Если пользователь является членом этой группы, проверяются атрибуты:

Мобильный телефон (**mobile**),

Электронная почта (**mail**),

а также Заметки на вкладке телефоны (**info**).

Как уже упоминалось выше, в поле Заметки можно указать предпочитаемый метод доставки одноразового пароля:

otpmail для отправки одноразового пароля по электронной почте.

otpsms для отправки одноразового пароля по SMS.

otpwww для отправки одноразового пароля по электронной почте на альтернативный почтовый ящик указанный в атрибуте **wWWHomePage**.

Так же атрибут **info** может содержать зашифрованный секретный ключ для генераторов TOTP.

Если в этом поле уже имеется текст, укажите метод доставки и, если надо ключ, в конце текста, отделив его запятой или пробелом.

В случае если атрибут **mobile** пустой, то будет использоваться атрибут **telephoneNumber**.

Так же, в случае если по каким-то причинам, невозможно использовать вышеуказанные атрибуты, можно создать в схеме Active Directory дополнительные атрибуты и указать их в файле **settings.json** следующими образом:

a_phone_attr приоритетный атрибут с телефонным номером

a_mail_attr приоритетный атрибут с адресом электронной почты

a_method_attr приоритетный атрибут с методом отправки и зашифрованным секретным ключом для генерации TOTP.

Альтернативные атрибуты являются **приоритетными**.

В связи с тем что на VPN шлюзах **checkpoint** нет возможности разрешить какой-то части пользователей подключаться без одноразового пароля, мы добавили возможность указать группу, члены которой могут вводить любой одноразовый пароль.

(параметр **otp_bypass_group** в секции **ldap_setting** файла **settings.json**).

Члены этой группы, могут подключаться, используя любые шесть цифр, например 000000.

При подключении, в качестве одноразового пароля может быть указан либо сгенерированный генератором одноразовый цифровой пароль (только в том случае, если у пользователя есть секретный ключ), либо пустое поле, в этом случае одноразовый пароль будет отправлен согласно предпочитаемому методу доставки, либо символ **s** или **m**.

В этом случае одноразовый пароль будет отправлен по SMS или электронной почте соответственно.

Использование LDAP over SSL

Необходимо наличие действительного сертификата на сервере, а также установленного корневого сертификата удостоверяющего центра, выдавшего сертификат для службы LDAP over SSL в доверенных корневых центрах сертификации, на сервере, где выполняется ***PowerMF***.

Так же в настройках ***PowerMF*** нужно указать FQDN LDAPS сервера, в случае если сертификат не содержит в поле альтернативного имени, IP адрес.

Далее рассмотрим работу с Active Directory, а в качестве Linux OS на которой выполняется ***PowerMF*** будем считать Red Hat и подобную OS.

Добавим корневой сертификат нашего удостоверяющего центра в доверенные на Linux OS:

```
yum install ca-certificates
update-ca-trust force-enable
cp ourrootca.crt /etc/pki/ca-trust/source/anchors/
update-ca-trust extract
```

Посмотреть какой именно сертификат используется сервисом LDAP over SSL можно утилитой

```
openssl:
openssl s_client -showcerts -connect <LDAP over SSL сервер>:636
```

Получив сертификат, можно убедиться кому и кем он выдан

Использование генераторов одноразовых паролей (программных или аппаратных)

Для использования генераторов TOTP необходимо чтоб секретный ключ был известен обеим сторонам.

Существуют аппаратные TOTP токены с запрограммированным на производстве ключом, и программируемые.

Программные же в любом случае требуют ввода ключа.

Как правило, это можно сделать либо сканированием QR кода, либо вводом строки в формате **Base32**

Для безопасности мы храним в LDAP зашифрованный ключ в виде **Base64** строки.

Если у вас уже есть ключ в формате **Base32**, вы можете его зашифровать при помощи утилиты **encryptkey**.

Она принимает следующие параметры:

-p пароль шифрования, который указан в **settings.json** (“**otp_key_encrypt**”:)

-k секретный ключ в формате **Base32**

-n если секретный ключ нужно сгенерировать (тогда параметр **-k** указывать не нужно)

-sqr показать QR код в терминале

-qr имя файла с QR кодом (указать **без расширения**, будет создан **PNG** фйл)

Если же его необходимо создать, то вы можете воспользоваться этой же утилитой, с параметром **-n**

а также можно создать QR код в виде png файла и, например отправить его почтой.

QR код может быть выведен на экран прямо в окно терминала если указать параметр **-sqr**

Примеры работы с утилитой показаны ниже:

```
encryptkey.exe -p secret1 -n -qr testuser
Encrypted secret key for LDAP info:
secretkey_UvbX5Cmr2uUVRc9DoBfj7VgZBtNUiu5ejmJhxvb3iVmvicgyOK90my1jm4hGUiaj
Secret key in Base32 format: I6BRAZTMGU4BJSVDAWV2KMASEUJWWHJJ
QR code saved in: C:\Users\Tuser\Tools\testuser.png
```

Настройка параметров

Параметры в файле settings.json

Секция **ldap_setting**

Параметр	Описание
fqdn	FQDN или IP адрес LDAP сервера
fqdn2	FQDN или IP адрес резервного LDAP сервера
ldap_port	LDAP порт (обычно 389)
ldaps_port	LDAP over SSL порт (обычно 636)
ldaps_enabled	включить LDAP over SSL (**true/false**)
base_dn	узел в дереве откуда начинать поиск пользователей
username_attr	атрибут имени пользователя, для Active Directory это **sAMAccountName**
bind_username_upn	имя пользователя, от имени которого будет производиться обращение по LDAP к службе каталога, либо в формате UPN (**<Имя пользователя>@<домен>**), либо в каноническом виде (в формате **CN=<Имя пользователя>,CN=<контейнер>.....,DC=<домен>,DC=local**)
bind_password	пароль пользователя
otp_group	имя группы, членам которой разрешен доступ в VPN (в формате **CN=<Группа>,CN=<контейнер>.....,DC=<домен>,DC=local**)
wo_otp_group	имя группы, членам которой разрешена первичная аутентификация (используется только при работе в качестве первичной аутентификации)
wo_otp_group_policy_attr	атрибут в службе каталогов, в котором указано имя групповой политики, передаваемое в 25 атрибуте (используется только при работе в качестве первичной аутентификации)
a_phone_attr	альтернативный атрибут в службе каталогов для телефонного номера
a_mail_attr	альтернативный атрибут в службе каталогов для электронной почты
a_method_attr	альтернативный атрибут в службе каталогов для указания метода доставки одноразового пароля
otp_bypass_group	имя группы, членам которой разрешена аутентификация при вводе любого одноразового пароля
fakepassword	недействительный пароль, который будет использоваться для блокировки пользователя в **Active Directory**
nestedgroup	искать принадлежность пользователя к группе рекурсивно (вложенные группы) (**true/false**)
useonlyoneattr	если в конфигурации указаны альтернативные атрибуты, и параметр useonlyoneattr установлен в **true**, то использовать только эти атрибуты, если же параметр useonlyoneattr установлен в **false**, то будет произведена проверка на то, что альтернативные атрибуты не пустые, если же они пустые, то будет использоваться стандартное для Active Directory поле
primaryauth	если установлен в **true** то сервис может использоваться для первичной аутентификации

Пример с двумя LDAP серверами:

```
"ldap_setting":{
   "fqdn":"dc01.testenv.local",
   "fqdn2":"192.168.0.7",
   "ldap_port":389,
   "ldaps_port":636,
   "Ldaps_enabled":true,
   "base_dn":"dc=testenv,dc=local",
   "username_attr":"",
   "bind_username_upn":"powermf@testenv.local",
   "bind_password":"P@ssw0rd123",
   "otp_group":"CN=OTP-VPN,CN=Users,DC=TESTENV,DC=LOCAL",
   "otp_bypass_group":"",
   "useonlyoneattr": false,
   "nestedgroup" : false
}
```

Пример с двумя LDAP серверами и заданными альтернативными атрибутами и указанием использовать только их:

```
"ldap_setting":{
   "fqdn":"dc01.testenv.local",
   "fqdn2":"192.168.0.7",
   "ldap_port":389,
   "ldaps_port":636,
   "Ldaps_enabled":true,
   "base_dn":"dc=testenv,dc=local",
   "username_attr":"uid",
   "bind_username_upn":"uid=powermf,cn=users,dc=testenv,dc=local",
   "bind_password":"P@ssw0rd123",
   "otp_group":"cn=OTP-VPN,cn=users,dc=testenv,dc=local",
   "otp_bypass_group":"",
   "useonlyoneattr": true,
   "nestedgroup" : false,
   "a_phone_attr":"mobile2",
   "a_mail_attr":"mail2",
   "a_method_attr":"description",
}
```

Секция **radius_setting**

Параметр	Описание
shared_secret	Секретный ключ
Port	порт (обычно 1812)
address	адрес, на котором слушать Radius дейтаграммы (можно оставить пустым)
ttimeotp	используется в тестовых целях и должен быть **false**

Секция **blockuser_params**

Параметр	Описание
attemps	количество попыток ввода OTP (в случае блокировки в Active Directory, должно совпадать с политикой в домене)
intime_mins	в течение какого времени, в минутах
blockfor_mins	блокировать на время, в минутах (в случае блокировки в Active Directory, не имеет значения так как настраивается политикой в домене)
enabled	0 - блокировка выключена 1 - блокировка в PowerMF 2 - блокировка в Active Directory
listblockedusers	выводить в файл лога информацию о заблокированных пользователях
country_list	использовать список блокировки по странам в файле **countryacl.json**, **true/false**
iplist	использовать список блокировки по IP адресам в файле **countryacl.json**, **true/false**

Секция **otp_params**

Параметр	Описание
valid_interval	интервал, в течение которого временный пароль действителен (только для паролей, отправленных через SMS/E-Mail)
otp_len	количество цифр в одноразовом пароле (на данный момент должно быть **6**)

Секция **smtp_params**

Параметр	Описание
enabled	включение работы с SMTP, **true** включено, **false** выключено
mail_from	пользователь, от которого будет производиться отправка письма
mail_from_name	имя от, которого будет отправлено письмо
smtpserver	IP или FQDN адрес SMTP сервера
smtpport	порт SMTP, обычно 25 или 465 для TLS
username	имя пользователя для аутентификации на SMTP сервере
smtp_password	пароль для SMTP соединения
smtpport	порт SMTP сервера
subject	тема письма
message	текст в теле письма, помимо кода
domain	smtp домен, например yandex.ru
tls	укажите **true** если используется SMTP over **TLS** или укажите **false** для использования метода **STARTTLS**
plain	если параметр установлен в **true** и параметр **tls** установлен в **false**, то отправка будет производиться открытым текстом
connection_timeout_sec	таймаут в секундах, на установку TCP соединения с сервером SMTP *
smtp_timeout_sec	таймаут в секундах, на всю SMTP сессию исключая ее установку
verify_certificate	проверять сертификат на SMTP сервере, в случае работы в режиме TLS

* Суммарное время (в секундах), затраченное на отправку письма, не превысит **connection_timeout_sec + smtp_timeout_sec**

Пример для почты Yandex:

```
"smtp_params":{
   "enabled": true,
   "mail_from":"demopowerc@yandex.ru",
   "mail_from_name":"PowerMF",
   "smtpserver":"smtp.yandex.ru",
   "smtpport":465,
   "username": "demopowerc@yandex.ru",
   "smtp_password":"Pass1230985",
   "subject":"Your OTP",
   "message":"OTP valid until  30 sec",
   "domain": "yandex.ru",
   "tls":true,
   "plain":false,
   "connection_timeout_sec": 5,
   "smtp_timeout_sec": 5,
   "debuglevel":0

}
```

Секция **sms_params**

Параметр	Описание
Enabled	включение работы с SMS, true включено, false выключено
Smsprovider	провайдер SMS, **mts** или **sms discount**
Smslogin	имя пользователя для аутентификации на SMS шлюзе
Naming	имя отправителя
Smspassword	пароль для аутентификации на SMS шлюзе
Numbertotallen	длина телефонного номера включая код страны и оператора
Defaultcountrycode	код страны по умолчанию
connection_timeout_sec	таймаут в секундах, на попытку отправки сообщения *

* Суммарное время (в секундах), затраченное на отправку сообщения, не превысит **connection_timeout_sec**

Поддерживаются два провайдера SMS: **МТС** и **СМС Дисконт.**

В атрибуте пользователя, номер телефона должен храниться в формате:

+<код страны><код оператора><номер телефона>

Либо:

<код страны><код оператора><номер телефона>

Если номер хранится в формате:

8<код оператора><номер телефона>

то он будет преобразован к виду **<код страны по умолчанию><код оператора><номер телефона>**, так как код страны невозможно определить, то добавляется код страны по умолчанию.

Пример для СМС Дисконт:

```
"sms_params":{
    "enabled": true,
    "provider": "sms discount",
    "message":"OTP valid until 30 sec",
    "smslogin":"DemoLogin1",
    "smspassword":"1234567",
    "naming": "PowerC",
    "connection_timeout_sec": 5,
    "debuglevel": 0
}
```

Блокировка подключения

Блокировка аутентификации по IP адресам и странам

Параметры блокировки адресов и стран указываются в файле **countryacl.json**

Существует два режима работы блокировки по странам и адресам:

- Списки разрешенных адресов/стран (**ip_allowlist** и **country_allowlist**) и запрещено все что в них не разрешено.
- Списки запрещенных адресов/стран (**ip_denylist** и **country_denylist**) и разрешено все что в них не запрещено

Режим работы определяется параметрами **ip_default_block** и **country_default_block**.

Значение **true** означает использование списка разрешенных адресов/стран.

Значение **false** означает использование списка запрещенных адресов/стран.

Адреса IPv4 указываются в формате **xx.xx.xx.xx** или **xx.xx.xx.xx/xx**, например, **1.2.3.4, 8.8.0.0/16** и разделяются запятой.

Страны указываются в формате **XX** (так же как в базе данных RIPE), например **RU, BY, US** и разделяются запятой.

Определение страны производится через базу данных RIPE.

При этом запросы кэшируются и на одни и те же адреса не посылаются повторно (размер кэша ограничен и старые записи замещаются новыми).

Параметры в файле countryacl.json

Параметр	Описание
country_allowlist	список разрешенных стран
country_denylist	список запрещенных стран
country_na_block	блокировать пользователя, в случае невозможности получения информации о стране **true/false**
country_default_block	если установлен как **true**, то будет использоваться список разрешенных стран country_allowlist, а все остальные блокируются, если же установлен как **false**, то используется список запрещенных стран, country_denylist, а все остальные разрешены
ip_allowlist	список разрешенных IP адресов
ip_denylist	список запрещенных IP адресов
ip_default_block	если установлен как **true**, то будет использоваться список разрешенных IP адресов ip_allowlist, а все остальные блокируются, если же установлен как **false**, то используется список запрещенных адресов, ip_denylist, а все остальные разрешены

Пример настройки:

Разрешены страны **Россия** и **Беларусь**, все остальные запрещены
Сеть **8.8.0.0/24** запрещена, все остальные разрешены

```
{
    "country_allowlist": "BY,RU",
    "country_denylist": "",
    "country_na_block":true,
    "country_default_block":true,
    "ip_allowlist": "",
    "ip_deny": "8.8.0.0/16",
    "ip_default_block":false
}
```

Блокировка пользователя при попытке подбора одноразового пароля

Существует возможность временной блокировки пользователя, например на 15 минут, при нескольких подряд неуспешных попытках в течение заданного времени.

За это отвечает секция **blockuser_params** в файле **settings.json**.

Однако следует помнить, что, если производятся попытки подбора одноразового пароля, значит пароль на учетную запись уже скомпрометирован. (в общем случае это не всегда так, но чаще всего, пароль на учетную запись проверяется до проверки одноразового пароля)

Так же, есть возможность включить режим блокировки в **Active Directory**, тогда сохраняется концепция управления всем функционалом в **Active Directory** с одной стороны, и позволяет обратить внимание на факт утечки пароля учетной записи с другой стороны.

Блокировка пользователя в службе каталогов, производится путем многократных попыток аутентификации с неверным паролем, указанным в параметре в параметре **fakepassword** секции **ldap_setting**, данный пароль не должен использоваться в службе каталогов.

Для правильной работы блокировки, необходимо так же указать в параметре **attemps** секции

blockuser_params количество попыток ввода пароля, такое же как и в политике службы каталогов.

Режим первичной аутентификации

PowerMF может использоваться как Radius сервер для первичной аутентификации, один из сценариев такого использования рассмотрим ниже:

- В компании используется служба каталогов LDAP (например, Active Directory)
- Необходимо реализовать возможность подключения некоторых пользователей без двухфакторной аутентификации
- Разрешить подключение только из одной или нескольких стран, или даже с ограниченного списка IP адресов.
- Не пытаться аутентифицировать пользователя в службе каталогов, если он не является членом определенной группы.

Поскольку взаимодействие с VPN шлюзом и ***PowerMF*** в таком случае производится по протоколу Radius, то назначить нужную политику доступа по LDAP группе уже не получится.

Для этого можно использовать либо политику по умолчанию, либо назначенный атрибут и указать в нем имя политики, она будет передана VPN шлюзу как 25 атрибут.

К примеру, на Cisco ASA один экземпляр ***PowerMF*** можно использовать для разных туннельных групп как сервер первичной аутентификации и как сервер вторичной аутентификации.

А также можно развернуть два экземпляра ***PowerMF*** и использовать в одной туннельной группе их как серверы первичной и вторичной аутентификации.

По сравнению с использованием в качестве сервера первичной аутентификации LDAP каталога напрямую, это дает следующие преимущества:

- В случае ограничения стран/IP адресов, запросы на аутентификацию в службу каталогов направлены не будут.
- Сначала производится проверка членства в группе, а затем аутентификация.

Оба этих пункта избавят от блокировок учетных записей в службе каталога, по причине попытки их подбора.

Пример работы блокировки по странам:

```
2026/07/02 12:05:21 User: jthurman, client ip: 191.102.187.XXX, blocked by ACL, reason:  country US is not in allow list , Reject
2026/07/02 12:05:36 User: cortiz, client ip: 170.247.221.XXX, blocked by ACL, reason:  country BZ is not in allow list , Reject
2026/07/02 12:05:38 User: cayala, client ip: 170.254.179.XXX, blocked by ACL, reason:  country US is not in allow list , Reject
2026/07/02 12:07:10 User: blopez, client ip: 143.137.167.XXX, blocked by ACL, reason:  country UK is not in allow list , Reject
```

Установка

Установка из репозитория GitHub

Перейти в папку /opt

```
cd /opt
```

Выполнить:

```
git clone https://github.com/OlegPowerC/powermf.git
```

Перейти в папку powermf

```
cd powermf
```

Сделать исполняемым файл init.sh

```
chmod +x ./init.sh
```

И выполнить его

```
./init.sh
```

Дождаться появления информации о лицензии и сохранить ее

Связаться с нами по **e-mail: info@powerc.ru** или по телефону и приобрести лицензию

После получения файла **license.dat** скопировать его в папку **lic**

Для запуска как сервис выполнить

```
systemctl enable /opt/powermf/powermf.service
```

Запустить

```
service powermf start
```

Разрешить принимать дейтаграммы на нужный порт в файрволе

```
firewall-cmd --zone=public --permanent --add-port=1812/udp
firewall-cmd --reload
```

Журналирование

Основной журнал (**radius.log**) ведется в текстовый файл в папке logs.

Так же, если настроен Syslog сервер, то записи будут отправляться на него.

Пример сообщений из журнала radius.log:

```
2025/11/18 18:34:48 NAS: 192.168.0.1:32735, client ip: 79.XX.XX.XX, OTP for user: Vladimir.XXXX was entered in the second password field (used TOTP token), OTP valid, Accepted

2025/12/22 16:02:32 NAS: 192.168.55.1:46598,client ip: 176.XX.XX.XX, Sent OTP to user: Oleg.XXXX, to +7XXXXXXX, Challenge

2025/12/22 16:02:45 NAS: 192.168.55.1:46598, client ip: 176.XX.XX.XX, User: Oleg.XXXX, entered valid OTP, Accepted

2025/12/22 17:35:11 NAS: 192.168.55.1:46598, client ip: 81.XX.XX.XX, Sent OTP to user: Oleg.XXX, to oleg.XXXXX@XXXXX.com, Challenge

2025/12/22 17:35:38 NAS: 192.168.55.1:46598, client ip: 81.XX.XX.XX, User: Oleg, entered valid OTP, Accepted
```

Первое сообщение говорит о том, что пользователь Vladimir, сразу ввел код, полученный при помощи либо программного, либо аппаратного токена.

Второе сообщение говорит о том, что пользователю Oleg, код был выслан сообщением SMS, и следующее сообщение говорит о том, что пользователь правильно и вовремя ввел полученный код.

Третье сообщение говорит о том, что пользователю Oleg, код был выслан по электронной почте, и следующее сообщение говорит о том, что пользователь правильно и вовремя ввел полученный код.

Отдельно ведется журнал состояния отправленных SMS сообщений, (файл **sms.log**).

Пример сообщений из журнала sms.log:

```
2025/12/22 16:04:19 Client: PowerMF, message local id: 3, remote id: 6803307920 to: 7XXXXXXXXXX ,status: API POST

2025/12/22 16:04:22 Client: PowerMF, message local id: 3, remote id: 6803307920 to: 7XXXXXXXXXX ,status: submit to SMSC

2025/12/22 16:04:33 Client: PowerMF, message local id: 3, remote id: 6803307920 to: 7XXXXXXXXXX ,status: delivered

2025/12/22 17:02:00 Status queue len: 0
```

Этот журнал ведется службой, которая отслеживает статусы отправленных сообщений.
здесь:

- **local id** - идентификатор сообщения в ***PowerMF***
- **remote id** - идентификатор сообщения у провайдера

Далее телефонный номер, приведенный к виду <код страны><код оператора><телефонный номер> и статус, ниже приведен возможный статус сообщения:

- **submit to SMSC, queued, sending, part sent, accepted** - сообщение в обработке или доставлена только его часть
- **delivered** - сообщение доставлено
- **rejected**, **sender address invalid**, **incorrect id**, **not sent** - ошибка при работе с API провайдера.
- **not delivered, delivery error** - сообщение не было доставлено.
- **status not available** не удалось получить конечный статус в течение минуты и попыток более не будет.

Строка 2025/12/22 17:02:00 Status queue len: 0 записывается в журнал раз в час, и указывает на то, сколько сообщений находятся в очереди на получение статуса доставки.

Для провайдера МТС сообщения будут немного другими:

```
2025/12/23 11:59:28 Client: PowerMF, message local id: MSGZID-3, remote id: d06fc90a-e744-XXXX-XXXX-XXXXXXXXXXXX to: 7XXXXXXXXXX ,status: API POST

2025/12/23 11:59:31 Client: PowerMF, message local id: MSGZID-3, remote id: d06fc90a-e744-XXXX-XXXX-XXXXXXXXXXXX to: 7XXXXXXXXXX ,status: sending

2025/12/23 11:59:31 Client: PowerMF, message local id: MSGZID-3, remote id: d06fc90a-e744-XXXX-XXXX-XXXXXXXXXXXX to: 7XXXXXXXXXX ,status: delivered
```

Статус так же будет отличным:

- **sending, part sent, part delivered** - сообщение еще в обработке или доставлена только его часть
- **delivered** - сообщение доставлено
- **rejected, sender address invalid, incorrect id, not sent** - ошибка при работе с API провайдера
- **not delivered, not sent** - сообщение не было доставлено
  status not available - не удалось получить конечный статус в течение минуты и попыток более не будет.

В версии ***PowerMF*** под ОС Windows, журналирование ведется с использованием стандартного журнала Windows, после выпуска релиза данной версии, этот раздел будет дополнен необходимой информацией.

Отладка

В файле конфигурации есть параметры **debuglevel**, это глубина отладочной информации.

Максимум **255**

В случае запуска приложения из консоли отладочная информация будет выводиться на экран.

В случае запуска приложения как сервиса linux в ОС с systemd, отладочную информацию можно посмотреть в системном журнале:

```
journalctl -u powermf
```

Настройка VPN шлюза

Настройка шлюза VPN на примере Cisco ASA

```
laaa-server ADLDAP protocol ldap
aaa-server ADLDAP (inside) host 192.168.0.2
server-port 389
ldap-base-dn dc=EXAMPLE, dc=LOCAL
ldap-scope subtree
ldap-naming-attribute sAMAccountName
ldap-login-password TestPass123
ldap-login-dn cn=ASA, cn=Users, dc=EXAMPLE, dc=LOCAL
server-type microsoft

aaa-server RDTEST protocol radius
aaa-server RDTEST (inside) host 192.168.0.5
key radiuskeytest123
authentication-port 1812

tunnel-group TWTEST type remote-access
tunnel-group TWTEST general-attributes
authentication-server-group ADLDAP
secondary-authentication-server-group RDTEST use-primary-username
```

В примере:

192.168.0.2 — это адрес LDAP сервера

192.168.0.5 — это адрес Linux хоста, на котором запущен сервис ***PowerMF***

Настройка Active Directory

Настройка Active Directory с помощью Powershell

Создание пользователя:

```
$Username = "<имя пользователя>"
$Password = ConvertTo-SecureString "<пароль>" -AsPlainText -Force
$Name = "<Имя>"
$OU = "<путь>"
New-ADUser -Name $Name `
-SamAccountName $Username `
-UserPrincipalName "$Username@domain.local" `
-Path $OU `
-AccountPassword $Password `
-Enabled $true `
-PasswordNeverExpires $true `
-ChangePasswordAtLogon $false
```

Пример:

```
$Username = "asamfauser"
$Password = ConvertTo-SecureString "P@ssw0rd123" -AsPlainText -Force
$Name = "asamfauser"
$OU = "CN=Users,DC=example,DC=local"
New-ADUser -Name $Name `
-SamAccountName $Username `
-UserPrincipalName "$Username@example.local" `
-Path $OU `
-AccountPassword $Password `
-Enabled $true `
-PasswordNeverExpires $true `
-ChangePasswordAtLogon $false
```

Удаление пользователя:

```
Remove-ADUser -Identity "<имя пользователя>"
```

Пример:

```
Remove-ADUser -Identity "asamfauser"
```

Создание группы, членам которой будет разрешено получать коды:

```
New-ADGroup -Name <имя группы> -Path <путь, куда добавить группу> -GroupCategory
Security -GroupScope Global
```

Пример:

```
New-ADGroup -Name "VPNMFA" -Path "CN=Users,DC=EXAMPLE,DC=LOCAL" -GroupCategory
Security -GroupScope Global
```

Добавление пользователя в группу:

```
Add-ADGroupMember -Identity <имя группы> -Members <имя пользователя>
```

Пример:

```
Add-ADGroupMember -Identity "VPNMFA" -Members "Testuser"
```

Просмотр атрибутов (перечислим конкретные):

```
Get-ADUser "<имя пользователя>" -Properties <список атрибутов через запятую>
```

Пример:

```
Get-ADUser "Testuser" -Properties Info,mobile,mail
   DistinguishedName : CN=Testuser,CN=Users,DC=EXAMPLE,DC=LOCAL
   Enabled           : True
   GivenName         : Testuser
   Info              :
otpsms,secretkey_0000i00008g0000YVad0000000032xrOXVb10000_tVD600006nAeIVb00000000
   mail              : Testuser@example.ru
   mobile            : 8XXXXXXXXXX
   Name              : Testuser
   ObjectClass       : user
   ObjectGUID        : 33527000-0000-4309-000-9522b0006000
   SamAccountName    : Testuser
   SID               : S-1-5-21-3510006000-2088588912-100075000-1000
   Surname           :
   UserPrincipalName : TESTUSER@EXAMPLE.LOCAL
```

Изменение/добавление атрибута:

```
Set-ADUser -Identity "<имя пользователя>" -Replace @{<атрибут>="<значение
атрибута>";<атрибут>="<значение атрибута>"}
```

Пример:

```
Set-ADUser -Identity "Testuser" -replace @{mobile="+7XXXXXXXXXX";
mail="Testuser@example.com"}
```

Очистка атрибута:

```
Set-ADUser -Identity "<имя пользователя>" -CLear <список атрибутов через запятую>
```

Пример:

```
Set-ADUser -Identity "Testuser" -Clear mobile,mail
```

Удаление пользователя из группы:

```
Remove-ADGroupMember -Identity "<имя группы>" -Members "<имя пользователя>"
```

Пример:

```
Remove-ADGroupMember -Identity "VPNMFA" -Members "Testuser"
```

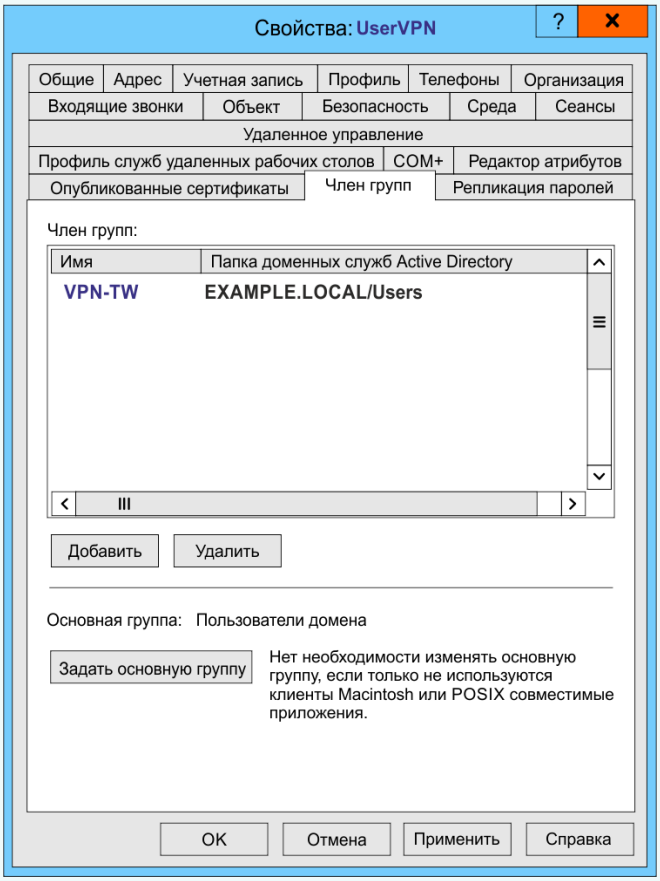
Получение списка пользователей, членов группы

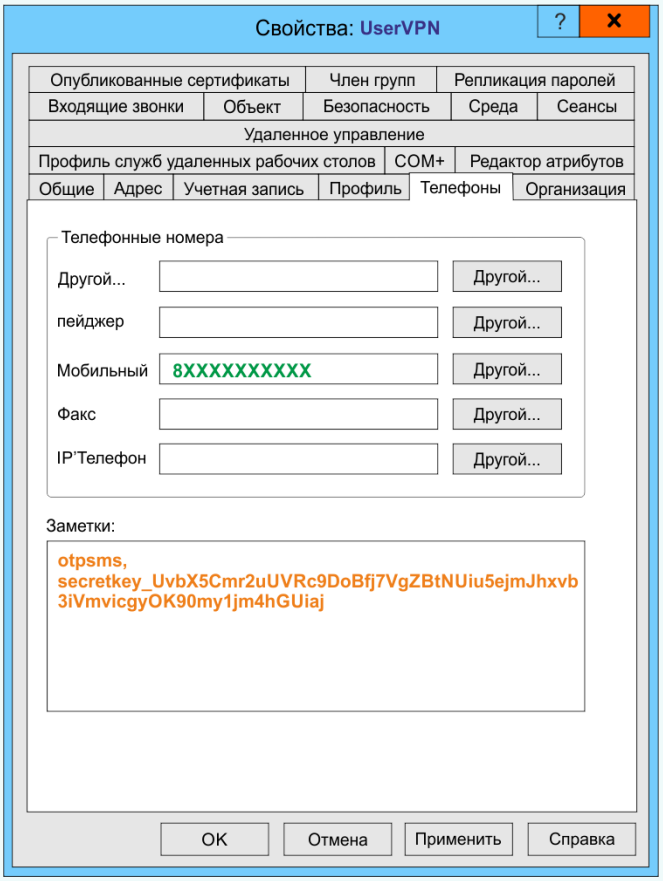
```
Get-ADGroupMember -Identity "<имя группы>"
```

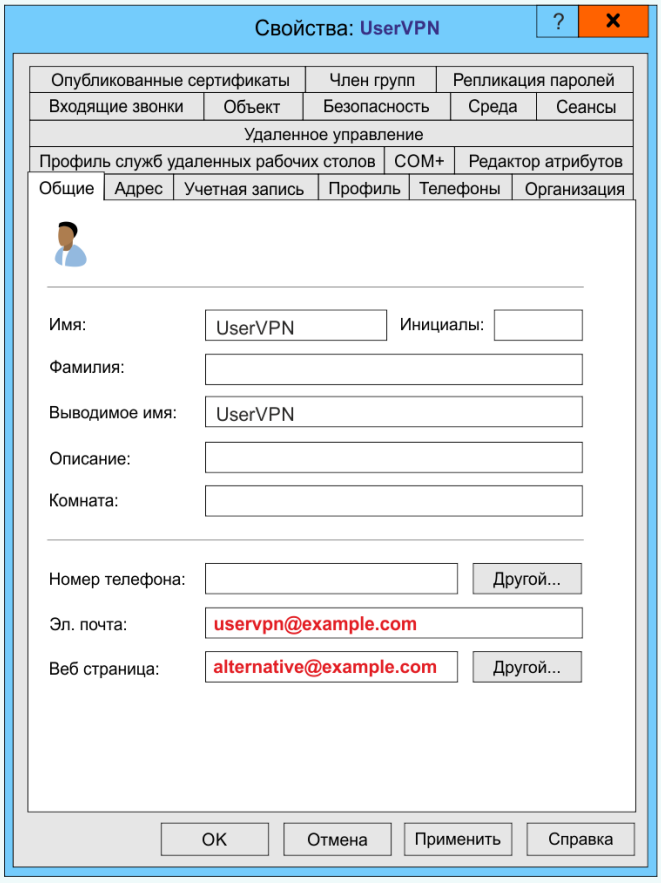
Пример:

```
Get-ADGroupMember -Identity "VPNMFA"
```

Пример настройки Active Directory через графический интерфейс







Тестирование

Тест при использовании в качестве VPN шлюза, Cisco ASA, можно использовать CLI:

```
test aaa-server authentication RDTEST host 192.168.0.5 username User password 123654
```

В случае указывания реального пользователя - члена группы, указанной в параметре **otp_group** у которого есть токен (**secretkey** в поле **info**) и пароля, сгенерированного генератором одноразовых паролей, в логе будет сообщение:

```
INFO: Authentication Successful
```

В случае указания неверного пароля, в логе будет сообщение:

```
ERROR: Authentication Rejected: AAA failure
```

Инструменты тестирования

Утилиты для тестирования используют файл настройки **settings.json** и таким образом можно проверить корректность настроек.

Для проверки связи со службой каталога, а также какие атрибуты будут использоваться, можно воспользоваться утилитой **testldap**:

```
./testldap  -u <Имя пользователя>
```

Пример:

```
./testldap  -u User1
Пользователь User1 член группы CN=VTEST-VPN,CN=Users,DC=EXAMPLE,DC=LOCAL
номер мобильного телефона (LDAP атрибут extensionAttribute6): +7XXXXXXX
E-Mail (LDAP атрибут extensionAttribute8): user1@example.local
Метод доставки сообщения (параметр в атрибуте extensionAttribute5): SMS на номер
мобильного телефона
```

Для проверки работоспособности доставки почты можно воспользоваться утилитой **testmail**.

Она принимает один параметр **-to,** адрес получателя тестового письма.

Так же можно проверить доставку SMS сообщений утилитой **testsms**.

Она принимает один параметр **-phone**, номер телефона на который отправить тестовое сообщение, затем в течение 60 секунд получается статус сообщения и записывается в файл **testsms.log.**

Данные о принадлежности адресов к стране, получаются из базы данных **RIPE**.

Для проверки ее доступности можно использовать утилиту **ripetest** указав в качестве единственного параметра **-i** IPv4 адрес.

Пример:

```
./ripetest -i 113.1.2.7
Country: CN
Network: 113.0.0.0/13
Maintainer: MAINT-AS58453
Origin AS 4837
```

Отказоустойчивость

Поскольку данные о пользователях получаются путем LDAP запроса к службе каталогов, то нет необходимости в резервном копирование базы данных пользователей.

Разумеется, это не отменяет очевидного факта, что резервное копирование самой службы каталогов необходимо.

Поэтому для резервирования ***PowerMF***, достаточно запустить еще один экземпляр с аналогичной конфигурацией.

Так же в каждом экземпляре можно указать до двух адресов службы каталогов, а так же можно указать различные почтовые серверы.

Со стороны VPN шлюза, можно настроить таймауты на переключение между Radius серверами меньше, чем таймаут на отправку почты и/или SMS в конфигурации ***PowerMF***, в этом случае, VPN шлюз, не дождавшись ответа от ***PowerMF***, переключится на другой ее экземпляр.

Если же таймаут на VPN шлюзе превышает таймауты на оправку кода в ***PowerMF*** то VPN шлюз переключится на другой экземпляр только в случае, если текущий экземпляр недоступен.

Так же благодаря возможности выбора методов отправки кода, пользователь всегда может выбрать альтернативный метод, если не получает код, например по CMC или же ввести код сразу, в случае если он обладает токеном

Изменения и дальнейшее развитие

В последней версии ПО все флаги в конфигурационных файлах включено/выключено настраиваются одинаково: true/false.

Добавлена возможность блокировки аутентификации по IP адресам или стране (данные о стране выбираются из базы данных RIPE).

В скором времени будет доступна версия под Windows (служба)
Планируется локализация на различные языки.

Планируется создание системы публикации QR кодов по одноразовым ссылкам.

Самое, пожалуй, существенное изменение в будущем, это добавление поддержки TPM, то есть хранение ключей шифрования в аппаратном модуле и шифрование всех чувствительных данных в конфигурации этими ключами.

Это будет гарантировать невозможность воспользоваться какими-либо учетными данными, даже обладая конфигурационным файлом.

Расположение файлов

Журналы расположены в папке **logs** в ОС linux.

Утилита для создания секретного ключа для генератора одноразовых паролей TOTP, расположена в папке **tools** в ОС windows и linux.

Утилиты:

- **testldap**
- **testmail**
- **testsms**
- **ripetest**

расположены в той же директории, что и исполняемый файл **powermf**.

Контакты

Компания **ООО «Пауэр Си»**

Россия, г. Санкт-Петербург

Ул. Таллинская 6-В

Телефон: +7(812)703-43-38

http://www.powerc.ru

mailto:info@powerc.ru

